守 望 者 零 信 任

面向业务资源的安全接入与共享白皮书 (Version 1.0)

单业务级精准发布 • 零公网暴露面交付 • 端到端安全加密

一、产品概述与核心价值

守望者零信任系统聚焦于企业内部网络业务的安全交付。系统支持将特定的业务端口（如 ERP、财务系统、开发环境、数据库等）独立发布为安全资源，并通过专属资源凭证建立端到端加密通道。

外部用户在保留原有操作习惯的前提下，直接通过本地常用客户端或浏览器即可完成业务对接。

传统远程访问的现实痛点与守望者应对策略：

- **1. 过度授权与横向扩散：**传统方案通常接入整个网段，单点失陷可能波及全网。守望者将访问权限严格锁死在单一服务端口（IP:Port），完全隔离非授权设备。
- **2. 桌面失控与数据越权：**常规远程控制需要出让整机控制权，存在操作盲区。守望者仅转发目标业务数据流，用户无法窥探或操作宿主机桌面。
- **3. 公网暴露与窃听威胁：**端口映射会将服务直接裸露于互联网探测中；第三方商业远控则存在数据过境云端被分析的合规风险。守望者采用无公网入站端口的主动通信架构，并全程执行双端强加密，杜绝第三方明文审查。

核心能力	实际收益
单业务级精准授权	权限精准锚定到单一端口，杜绝内网横向探测与越权漫游
端到端纯密文传输	业务数据在端侧完成加密封包，中转介质及第三方均无法还原明文
零公网服务暴露面	内部业务无需向互联网开放入站端口，规避自动化扫描与漏洞探测

原有应用无感使用	远程资源自动映射为本地端口，无缝兼容浏览器、SSH、远程桌面及数据库客户端
0.0.0.0 局域网按需共享	接入端支持开启全网卡监听，局域网内其他协同设备无需安装客户端即可同步复用
独立安全凭证体系	每个业务资源绑定专属 Link ID 与口令，实现细粒度生命周期管理

二、核心角色与访问模型

守望者通过清晰的“发布-凭证-接入”逻辑，建立跨网络的业务管道：

- • **Provider (资源发布端)**：部署在拥有目标业务访问权限的主机上。管理员指定需对外交付的内部 IP 与端口，并配置专属的链路标识（Link ID）与安全口令。
- • **Visitor (资源访问端)**：部署在需要使用业务的远程电脑上。用户输入对应的资源凭证，系统即在本地创建虚拟端口映射，支持单机独享或局域网共享。
- • **Resource ID + Key (资源凭证)**：业务访问的鉴权核心。客户端登录仅提供基础入网权限，必须持有特定资源的 Link ID 与安全口令，才能建立对应业务的数据链路。

三、功能特性与业务体验

1. 端到端强加密：保障业务数据绝对私密

数据在传输全链路中受到严密保护：

- • **端侧自主加解密**：业务数据在离开发布端前，已在内存层完成高强度对称加密，解密过程仅在合法访问端执行。
- • **零知识传输通路**：中转网络与服务器仅负责密文流的物理调度，无法解析、嗅探或篡改业务报文。
- • **合规与隐私隔离**：彻底消除桌面流过境第三方商业云平台带来的合规隐患，保障财务、研发及核心数据库等机密资产的安全。

2. 本地透明映射与团队共享（0.0.0.0 特性）

远程资源连通后，将在访问端生成对应的本地监听端口，用户原有的软件工具完全不需要做二次改造：

- • **单机独享（默认绑定 127.0.0.1）**：仅允许当前计算机上的应用程序连接，外界无法探测该端口。
- • **局域网共享（绑定 0.0.0.0）**：若出差团队位于同一会议室、现场分支或家庭网络，访问端可将监听地址设为 0.0.0.0。同网段下的手机、平板、协同电脑无需安装守望者客户端，直接访问该机局域网 IP 与端口即可共用业务，实现单点接入、全员协作。

远程业务类型	本地映射地址示例	实际使用方式
内部 Web / OA / ERP	`127.0.0.1:18080`	浏览器直接打开；若开启 0.0.0.0，组内全员浏览器可同频访问
Linux 服务器运维 (SSH)	`127.0.0.1:18022`	使用系统终端、Xshell 或 Putty 直接连接回环端口
Windows 远程桌面 (RDP)	`127.0.0.1:13389`	启动系统自带的远程桌面连接（mstsc）直连目标主机
核心业务数据库	`127.0.0.1:13306`	使用 Navicat、DBeaver、DataGrip 等专业管理软件顺畅操作
专有 TCP 业务协议	本地自定义分配端口	原生业务客户端指向本地端口正常工作

3. 业务隐形：消除互联网攻击面

系统基于出站安全连接技术构建通道。内部业务系统不需要公网 IP，也不需要在边界防火墙上配置任何入站端口开放规则。互联网扫描引擎（如 Shodan、Censys 等）无法感知内部资产的存在，从根源切断公网暴力破解和 0-Day 漏洞的主动探测。

4. 最小权限管控：锁定单一服务边界

访问者获得的仅仅是目标业务的报文收发权限。由于物理网络并未打通，访问端既无法向同网段其他主机发送数据包，也无法嗅探企业内部局域网广播，彻底阻断了黑客渗透中的横向移动路径。

四、典型应用方案

- **• 方案 1：企业日常协同与远程办公**

  办公室指定电脑发布内网 ERP 或知识库系统；异地办公员工在访问端完成本地端口映射后通过浏览器工作，使用体验与在办公室局域网内完全一致。

- **• 方案 2：外勤现场敏捷协作（0.0.0.0 团队复用）**

  技术交付团队在外场实施时，由一台设备作为 Visitor 连接公司内部集成测试环境，并绑定 0.0.0.0:8080。现场所有人员连接同一热点或局域网，即可同步调用开发接口，省去全员安装与账号配置成本。

- **• 方案 3：外部厂商临时技术支持与排障**

  第三方专家协助排查故障时，Provider 仅发布涉事主机的单个 SSH 或 RDP 端口。技术服务结束后，发布端一键删除该规则，远程访问权限即刻熔断。

- **• 方案 4：关键生产数据库隔离运维**

  开发人员需要查看核心库数据时，通过本地工具安全直连对应虚拟端口。即便员工处于公共网络环境，端到端密文封装技术也能有效抵御公共 WiFi 下的网络抓包与账密窃取。

五、常见远程访问方案对比

评估维度	传统 VPN 方案	商业远程桌面 (如向日葵)	公网端口映射 (NAT)	守望者零信任系统
访问控制粒度	整个局域网段	整台电脑桌面控制权	单个公开业务端口	**细粒度业务服务级（IP:Port）**
数据通信隐私	依赖 VPN 服务商配置	画面流经第三方商业云	通常为明文或依赖业务 SSL	**双端端到端强加密，第三方无法读取**
互联网暴露面	需开放 VPN 入口网关	依赖外部公有云中转	业务端口直接裸露公网	**零公网暴露面（服务完全隐形）**
横向扩散风险	极高（内网全开）	高（受控机易成跳板）	中（单点漏洞可能被攻破）	**杜绝扩散（物理隔离在单一服务）**
多端协同便利性	全员逐一配置账号规则	需购买多个商业并发席位	需配置专线与静态公网 IP	**支持 0.0.0.0 局域网单机接入整组复用**

原有软件兼容	易产生本地路由冲突	改变习惯（操作画面交互）	保持原有操作方式	**完全透明无感（映射为本地端口使用）**

六、安全运行与运维规范

- **1. 凭证分级流转：**Link ID 与口令具备访问特定业务的能力，应按最小特权原则一对一安全交接，严禁在未加密的公共聊天群中流转。
- **2. 0.0.0.0 场景防护建议：**在启用 0.0.0.0 全网卡广播模式前，应确认当前所在局域网环境（如团队内部热点、可信公司内网）安全受控，避免在机场、咖啡厅等不可信公开网络下开放该选项。
- **3. 宿主安全不降低：**守望者负责网络边界隐身与通信加密，目标业务系统自身的弱口令排查、用户身份验证及内部越权防护仍应严格执行标准安全基准。
- **4. 权限即时收回：**发布端享有资源的绝对控制权。合作终止或排障结束后，在界面中删除对应配置即可在数秒内切断远程通信。

守望者：业务精准直达，网络隐形无感。

守望者网络安全实验室 © 版权所有